IT INFRASTRUCTURE AUDIT & GRC COMPLIANCE STRATEGY

CREPLEY INC. – AUTOMOTIVE MANUFACTURING & DEALERSHIP OPERATIONS

ROLE: CYBERSECURITY & GRC LEAD

MARCH 2025

EXECUTIVE SUMMARY

Project Scope: IT Infrastructure Audit & GRC Compliance Strategy

Organization: Crepley Inc. (Automotive Manufacturing & Dealership)

Overview This audit identifies critical security gaps within Crepley Inc.'s hybrid work environment, specifically addressing the lack of VPN protocols and unmanaged remote access. The report provides a technical and regulatory roadmap to secure mission-critical assets, including customer PII and proprietary car designs.

Key Findings & Framework Alignment

Risk Quantification: Identified and triaged four critical risks (Likelihood vs. Impact scores of 5/5) related to data breaches, malware propagation, and business continuity.

Maturity Modeling (COBIT): Established a strategic path to transition organizational capability from Level 0 (Non-Existent) to a target of Level 5 (Optimized).

Technical Safeguards (CIS Controls): Mapped specific sub-controls, including Email/Web Browser Protections (Control 7) and Network Port Limitation (Control 9), to remediate firewall deficiencies and unauthorized traffic.

Regulatory Compliance (PIPEDA): Developed a comprehensive 10-point implementation plan ensuring 100% adherence to **Canada's Fair Information Principles**.

Conclusion By implementing the recommended stateful firewalls, SIEM tuning, and "Principle of Least Privilege" access, Crepley Inc. will achieve a resilient security posture that protects both its reputation and its operational continuity.

INTRODUCTION:

This final report is going to be on my company called Crepley Incorporated. Crepley incorporated is a car dealership/production company. This is an organization with its headquarters in Ottawa, Ontario. We have established several branches in 15 cities in Canada, with an employee number of over 800. We have several established departments within the industry, including our marketing department, our finance department, our Human Resources department in charge of hiring and workers welfare, as well as our customer relationship management departments and IT.

We are currently leveraging a web server onsite. Our employees are enabled to use their computer systems and external devices for work from home or whatever remote location they may choose for a period of time. This is being done without the use of a Virtual Private Network.

RISK ASSESSMENT:

In determining the value of information if stolen, the value could be categorized as of extremely high value. This is because, in the event of a compromised server network, customer information could be stolen, leading to reputational damage. This would also lead to lots of monetary loss from potential court cases. There is also the issue of copyrighted materials being compromised and sold, hence putting the company in a tight spot. Whatever secrets may have made Crepley a leading organization in the car dealership/manufacturing business would be out in the world for everyone to replicate. This forecasts significant loss for the organization.

In identifying the assets potentially compromised in a breach to Crepley's network, we can present assets such as customers credit/debit card information, customers home addresses, as well as their full names and emails. We can also highlight patents of the company's car designs and mode of dealing business and getting the parts used to make their cars come to life in the way they do.

In identifying cyber threats, worthy of note would be the risk of a malware potentially spreading on the company's network. The allowance of any device at any location, would also mean a lack of restriction and poor firewall rules. This would mean that, should a device on a network be infected as a result of the carelessness of the employees, the entire company network could suffer the consequences. This could hence lead to a disruption of business continuity, as we currently only conduct data and server backups once a month. A compromise of our network would make it extremely difficult to get crucial systems back online to conduct business again, thereby possibly delaying customer orders. It could also disrupt the continuity of production as blueprints would be stored on the server as well.

In identifying potential vulnerabilities to Crepley, the most obvious one to start with at the moment would be the risk of missing out on uncommon login attempts. The allowing of employees to use their own devices from whichever location of their choosing would make it difficult for an Intrusion Detection System to spot "anomalies" like, a strange location, or a strange login time. There is also the very possible incident of a zero-day attack.

In analyzing the current controls, there a number of things to consider and recommendations to make for improvements. Employees cannot be allowed to work remotely with their own devices. If employees are to work remotely, it should be with company provided devices that have been previously configured and locked down. This would also help in improving the accuracy of the Intrusion Detection Systems put in place. It would also be recommended for tighter firewall rules to be put in place. A stateful firewall would be preferred for tighter security regardless of the fact that it may be more resource-intensive.

In calculating the likelihood vs the impact of each risk listed, we go through the previously listed vulnerabilities and cyber threats. We will classify these between critical, high, medium and low.

- Risk 1: The absence of a stateful firewall configuration is a high priority risk. This would lead to the very likely event of unauthorized devices to join the company's network hence gaining access to its data and customers data and selling it on the dark web. The impact of this risk event should it occur, can be classified as crucial. This verdict is given considering the reputational damage the company could suffer after this event occurs. The score for this risk would be 5.
- Risk 2: The possibility of disruption of business process or business continuity is also very likely event that could occur as a result of the company only conducting backups once a month and not using a cloud-based provider. This would mean the company would struggle to get critical systems back online in the event of a breach. The impact of this event can be considered critical, as the company could lose millions during this downtime as they would not be able to process or fulfill customers' orders. Time is money. The score for this risk would be 5.
- Risk 3: The risk of malware spreading across the company's network is a high priority risk as well. If one device on the network is infected, it could risk spreading across the network and affecting other devices. This could lead to complete shutdown of business operations. Hence, the impact of this can be considered critical if not mitigated on time. The score for this risk would be 5.
- Risk 4: Damage to reputation is another risk to be considered as a result of customer data being compromised. This could lead to speculations and skepticism about and around the company. This may lead to business partners backing out and customers suing and not patronising going forward. The score for this risk would be 5.

In doing the final classification of these risks:

- Risk 1 can be classified as a critical risk.
- Risk 2 can be classified as a critical risk
- Risk 3 can be classified as a critical risk
- Risk 4 can also be classified as a critical risk.

COBIT:

Risk 1: based of this risk that has to do with the implementation of a stateful firewall, Crepley is currently on capability level 0, as this control has not been implemented. However the company aims to be at capability level 5.
Risk 2: based on this risk that has to do with the disruption of business continuity, the company can be said to be on capability level 4. The reason for this is, the company currently conducts backups on a monthly basis, meaning it is a process that is being monitored and controlled, even if it may not be the best at the moment. However, the company aims to be at level 5 which has to do with continuous improvement.

Risk 3: based on this risk which has to do with the risk of malware spreading on the company's' network from the infection of one device, it can be said that the capability level of the company on this front is 0. This is because the company still implements a free system which allows employees to any device for their jobs without a specific locked down system provided by the company. However, the company aims to be at capability level 5.
Risk 4: this risk has to do with reputational damage that leaked customer data could cause the company. On this front it could be said the company is on capability level 0. This is because the possibility of this risk coming to fruition is very high due to the open device system the company permits their employees. This could easily lead to compromise of the company network and theft of customer data. The company aims to be at capability level 5.

CIS CONTROLS:
CIS Control 7 – Email and Web Browser Protections

- Sub-control 7.9: Block Unnecessary File Types.
- Sub-control 7.7: Use of DNS Filtering Services.
- Sub-control 7.4: Maintain and Enforce Network-Based URL Filters.

These controls would work in tackling the potential risk posed by the absence of a Virtual Private Network at the company, as well as the issue of employees being free to access whatever sites they want with whatever devices. This effectiveness of this control can be measured by monitoring to see if there is a trend of reduced email compromises, reduced successful phishing attacks, and also by the number of sites blocked that employees may have tried to access.

CIS Control 6 – Maintenance, Monitoring and Analysis of Audit Logs

- Sub-control 6.4: Ensure Adequate Storage for Logs.
- Sub-control 6.7: Regularly Review Logs.
- Sub-control 6.8: Regularly Tune SIEM.

These controls would work in mitigating the issue of a an inefficient IDS system, as well as the providing a quicker recovery time for critical systems. Providing adequate storage for logs would help the company be able to review a larger number of logs and recover faster from an attack or spot a potential attack before it happens. The measurement of the effectiveness of this control would be by gauging if the company does go on to have a quicker recovery time, and

also, the if they experience spotting an increased number of anomalies long before time, hence preventing a break in business continuity.
CIS Control 5: Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers.

- Sub-control 5.1: Establish Secure Configurations.
- Sub-control 5.4: Deploy System Configuration Management Tools.
- Sub-control 5.5: Implement Automated Configuration Monitoring Systems.

These controls would help in mitigating the issue of use of personal devices for work, hence risking the company's network. Any software or hardware being used would be vetted and have configurations added under this new control. The measurement of the effectiveness of this control can be taken from monitoring the amount of anomalies arising on the IDS systems stemming from unrecognized devices at unrecognized locations. A decrease in these numbers could suggest the control is working effectively.

CIS Control 8: Malware Defenses.

- Sub-control 8.1: Utilize Centrally Managed Anti-Malware Software.
- Sub-control 8.2: Ensure Anti-Malware Software and Signatures Are Updated.
- Sub-control 8.4: Configure Anti-Malware Scanning of Removable Media.

These controls would aid in mitigating the issue of malware potentially crippling the company's systems. These would also help scan potential removable media devices employees may insert into company systems connected to the company network for whatever reason. The measurement of the effectiveness of this control can be judged by monitoring the amount of hits anti-malware software detects or spots at routine scans.

CIS Control 9: Limitation and Control of Network Ports, Protocols, and Services.

- Sub-control 9.3: Perform Regular Automated Port Scans.
- Sub-control 9.4: Apply Host-Based Firewalls or Port-Filtering.
- Sub-control 9.5: Implement Application Firewalls.

These controls would help the cause of creating a functional and effective firewall that would be tightly configured enough to secure the company's networks. This control would be measured by tracking the number of unauthorized blocked traffic from coming into the company's network.

PIPEDA:

PIPEDA (Personal Information Protection and Electronic Documents Act), is a Canadian regulation that has 10 fair information principles. These principles will be explored in relation to how the company can abide by them, hence strengthening security and being law abiding:

- Accountability: In order to abide by this principle, the organization must develop a privacy management plan. They need make sure they constantly audit their information management and for this they may need to employ both an internal and an external auditor. Proper data handling practices must also be followed to ensure data is discarded of properly after it is no longer in use. Clearly defined incident management protocols

must also be implemented to ensure in the event of an incident, the customer data will be protected.

- Identifying Purposes: In meeting up with this principle, Crepley can use terms and conditions prompts to ensure customers consent to its data sharing and collection terms. These terms must also clearly outline why it may be necessary to collect or store any sort of personal information, and must also be revised if the company requires additional use or access to additional data in the future.
- Consent: The organization must have a complete collection of details about what is being done with customers information, what information is being collected, and with whom the information is being shared with to meet up this principle. Again, this can be done with these of a terms and conditions form for the individual to either accept or decline.
- Limiting Collection: in fulfillment of this principle, Crepley must ensure the amount of personal information being collected is absolutely necessary, and must be honest about the purpose for which makes collection of said information, necessary. Staff of the organization must also be educated on why the company needs the personal information they collect, in a way in which they would be able to explain it themselves.
- Limiting Use, Disclosure and Retention: In compliance with this policy, the organization may conduct internal audits very often to ensure its employees are not misusing customers information. The further ensure this is monitored, the company can implement the principle of least privilege such that all employees are only privy to the minimum amount of information or sensitive data that is required for them to complete their jobs. Also, proper data handling practices must be ensured such that data is disposed of properly and discreetly when no longer required.
- Accuracy: in accordance with this policy, the company is responsible for updating customer information. This can go to the updating of customer credit/debit cards information, as well as possible ads preferences on company's car dealership website. Also, the reason for collection of customer information must be kept current, accurate and honest.
- Safeguards: in accordance with this principle, Crepley is responsible with keeping customer information safe and set up safeguards according to the levels of sensitivity of the information. This is to prevent theft and sale of customer information. Implementation can see setup of proper physical on-site security, such as security agents, and bollards to prevent damage to on-site facilities. Crepley may also employ controls to ensure periodic vulnerability assessments on its systems and firewall setups to patchup any outdated software or password policies. Again, only employees who need to access information should be given access to sensitive information. A need-toknow basis strictly.
- Openness: In fulfilling this principle, Crepley must be ensure complete transparency either verbally or through documentation to customers and general public in informing them what exactly is being done with their data, as well as what policies are in place to ensure data protection. This documentation must be made simple to understand and not aim to confuse customers into signing up to what they may not understand. Crepley staff

must also be thoroughly educated on how to respond to customer inquiries asking about their data protection. It should also explicitly be stated who may be responsible for the data security and how the organization plans to respond to incidents if they do happen. An example could maybe a partnership with an insurance company to ensure in the event of loss, Crepley would be able to compensate their customers nonetheless.

- Individual Access: In abiding by this principle, in the event that customers request to be informed of what personal information of theirs the company has access to, Crepley must be forthcoming with this information. Crepley must ensure that they respond within 30 days of the request, inform the inquisitor that they may require additional time if they do. There must also be willingness to update information in the event that innacurate information is being accessed or stored, or information outside the scope of what was supposed to be accessed by Crepley, is being accessed.
- Challenging Compliance: In the event of a complaint filed against Crepley, the organization must ensure to either provide proof that they do in fact comply with these policies, or adjust their practices to fall in line. A complaint should not be ignored, and the date of the complaint must be recorded. An auditor may be handed the job to ensure the company is in line with any policy breaches being complained about, otherwise, do what is necessary to come to a resolution nonetheless.

CONCLUSION:

In conclusion, the implementation of the COBIT controls seem to solve the potential issues the organization may have suffered, and would indeed push towards the goal of COBIT capability level 5. This would mean continuous monitoring of Intrusion Detection Systems to spot potential struggles or malfunctions. The number of incidents suffered or thwarted must also be closely monitored in order to adjust these controls accordingly. With this, Crepley is sure to keep the momentum going in terms of compliance, security, and business continuity.